



Title: Firewall Risk Identification Tool – “FireFind”

Executive Summary:

Triskele Labs has identified the need for comprehensive and open source tool to streamline the review of firewall rule sets across a variety of vendor platforms. Firewalls are a crucial piece of software for any organisation and are often the key control in place between their sensitive internal network data and treat actors trying to enter the network from the Internet. Too often, the Triskele Labs Digital Forensics and Incident Response (DFIR) team has responded to incidents resulting from dangerous ports and services being allowed through a firewall, which the victim organisation did not know about, as they did not have an easy method to review these firewall rules, which may have grown out of control over time. Existing solutions are often embedded within vendor ecosystems or require costly third-party tooling, limiting accessibility and transparency. FireFind is intended to be a purpose-built tool designed to ingest exported firewall rule data — in formats such as CSV or XLSX — from common platforms including Fortinet, Sophos, Barracuda, Checkpoint, and WatchGuard. It parses and analyses these rule sets to identify high-risk configurations, such as open administrative ports, excessive allow-any rules, or misconfigured inbound policies. The tool produces a machine-readable CSV output for technical review, as well as a formatted PDF report suitable for delivery to stakeholders. *FireFind* aims to provide repeatable, vendor-agnostic rule analysis to help security teams and auditors quickly identify exposure and prioritise remediation across heterogeneous firewall environments. Given that the tools being analysed are commercial (e.g., Fortinet, Sophos), Triskele Labs will provide the firewall exports to be used as test files for this project, for each brand as required.

Background:

Firewalls remain a critical component of perimeter security, but in many organisations, firewall rule sets become bloated, misconfigured, or outdated over time—introducing significant security risks. Despite this, systematic review of firewall rules is often overlooked due to the complexity of rule formats, lack of standardisation across vendors, and limited tooling. Existing solutions are typically vendor-specific or

commercially licensed, making them inaccessible for smaller organisations or independent auditors. Triskele Labs frequently encounters these challenges during client engagements, where high-risk rules such as exposed administrative ports or overly permissive access are common. There is a clear need for a transparent, open source solution to simplify rule analysis, enable repeatable audits, and support remediation prioritisation across diverse firewall technologies. FireFind is designed to meet this need, providing a platform-agnostic, cost-effective tool that enhances security posture through better firewall policy visibility.

Over time, Triskele Labs envisages this tool will be built to work with a vast range of firewall vendors; however initially, the intention is to focus on major brands and especially brands used by SMEs. It may be appropriate to build on top of an existing open-source tool to begin this project, or it may be more appropriate to start from scratch.

Objectives:

Functional Requirements – FireFind

- To ingest firewall rule sets exported in CSV or XLSX format from major vendors such as Fortinet, Sophos, Barracuda, Checkpoint, and WatchGuard (as provided by Triskele Labs).
- To parse and normalise rule data from varied vendor formats into a consistent internal structure suitable for analysis.
- To identify high-risk rules using a rule-checking engine that flags dangerous configurations (e.g., open administrative ports, allow-any rules, overly broad source/destination ranges).
- To allow the risk detection logic to be updated or extended via a configurable and easily editable rule set.
- To generate technical output in CSV format, listing each flagged rule with contextual detail, severity, and rationale.
- To produce a basic PDF report summarising key findings, suitable for distribution to non-technical stakeholders.
- To operate as a standalone, on major Windows or Linux systems, as an open-source utility without requiring paid dependencies.

Constraints & Limitations

C&L:

- The tool must be written using open-source libraries only, avoiding any commercial dependencies to ensure full transparency and accessibility.
- It must support execution on both Windows and Linux systems to ensure compatibility across different environments.
- The tool must accept rule set exports in common structured formats (CSV, XLSX).
- It must be capable of handling large rule sets efficiently.
- Configuration files (e.g., for rule definitions and thresholds) must be easily editable by end users.
- Output must be generated in standard formats (CSV for technical teams, PDF for stakeholders) to allow for direct consumption without additional transformation.
- The solution must run as a standalone executable or script, avoiding the need for complex runtime environments or installers (e.g., no requirement for Java or .NET runtimes).

Scope:

Must Haves

- Ability to ingest firewall rule exports in CSV and XLSX formats from major vendors (Fortinet, Sophos, Barracuda, Checkpoint, WatchGuard).
- Parsing and normalisation of rule data into a consistent format for analysis.
- Rule engine to identify high-risk configurations (e.g., open admin ports, allow-any rules).
- Editable configuration for rule logic and thresholds.
- Output of technical findings in CSV format.
- PDF report generation summarising key findings.
- Standalone execution with no external dependencies, operable on Windows and Linux.
- Fully open-source, using no commercial libraries or components.

Nice to Haves

- Support for batch processing of multiple rule sets in one run.
- Visual indicators or severity scoring in the PDF report.
- Tagging or categorisation of rules by function (e.g., admin, web, user access).
- Detection of redundant or shadowed rules.
- Validation logic checks for malformed or incomplete rule entries.

Optional Outcomes

- Basic web-based UI for file upload and results viewing.
- Historical trend analysis for rule set changes over time.
- Support for additional firewall vendors beyond the initial scope.
- Auto-detection of vendor type from import file structure.